



UNIVERSITÀ DEGLI STUDI DI SALERNO

DIPARTIMENTO DI INGEGNERIA DELL'INFORMAZIONE ED
ELETTRICA E MATEMATICA APPLICATA

Corso di Laurea Magistrale in Ingegneria Informatica

Algoritmi e Protocolli per la Sicurezza Project Work

Gruppo 41

ANNO ACCADEMICO 2024/2025

Indice

1	Premessa	3
2	WP1: Modello	5
2.1	Definizione degli Attori Onesti	5
2.1.1	Studente Erasmus	5
2.1.2	Università di Salerno	6
2.1.3	Università di Rennes	6
2.1.4	Autorità di Certificazione	6
2.2	Threat Model	7
2.2.1	Lo Studente Disonesto	8
2.2.2	Il Funzionario Interno Malevolo	8
2.2.3	L'Ingegnere Sociale	9
2.2.4	L'Intercettatore	9
2.2.5	Il Cacciatore di Vulnerabilità	9
2.3	Proprietà del Sistema	10
2.3.1	Confidenzialità	10
2.3.2	Integrità	10
2.3.3	Autenticità	10
2.3.4	Trasparenza	10
2.3.5	Efficienza	11
2.3.6	Non Ripudio	11
2.4	Struttura delle Credenziali	12
3	WP2: Soluzione	13
3.1	Introduzione	13
3.2	Processo di Autenticazione degli Attori Onesti	13
3.2.1	Fast Identity Online 2 (FIDO2)	13
3.2.2	MultiFactor Authentication (MFA)	15
3.2.3	Studente Erasmus	16
3.2.4	Università di Rennes e di Salerno	19
3.2.5	Certificate Authority	20
3.3	Funzionamento generale del sistema	22
3.3.1	Accreditamento delle Università	22
3.3.2	Generazione delle Credenziali	23
3.3.3	Presentazione Selettiva delle Credenziali	24
3.3.4	Meccanismo di Revoca delle Credenziali	25
3.4	Dettagli Tecnici e Protocolli Utilizzati	25
3.4.1	Firme Digitali	25
3.4.2	Certificati Digitali	27
3.4.3	Merkle Tree	27
3.4.4	Blockchain e Smart Contract	27
3.4.5	Protocollo Sicuro di Trasmissione	29

3.4.6	JSON	29
4	WP3: Analisi della Sicurezza	30
4.1	Studiante Disonesto	30
4.1.1	Il Funzionario Interno Malevolo	31
4.1.2	L'Ingegnere Sociale	32
4.1.3	L'Intercettatore	33
4.1.4	Il Cacciatore di Vulnerabilità	34
4.2	Verifica delle Proprietà di Sicurezza	34
5	WP4: Implementazione	36
5.1	Scelte Implementative e Assunzioni	36
5.2	Architettura dell'Implementazione	36
5.3	Fasi della Simulazione	37
5.3.1	Configurazione Infrastruttura delle PKI Università	37
5.3.2	Inizializzazione Wallet e Richiesta Credenziali	38
5.3.3	Preparazione delle Credenziali	39
5.3.4	Firma Digitale delle Credenziali	40
5.3.5	Registrazione della Credenziale sulla Blockchain	40
5.3.6	Emissione sul Wallet dello Studente	41
5.3.7	Generazione Presentazione Selettiva	42
5.3.8	Verifica Università di Salerno	43
5.4	Test	45

1 Premessa

Nel contesto del programma Erasmus e, più in generale, della mobilità studentesca internazionale, la condivisione di credenziali accademiche (esami superati, titoli ottenuti, attestazioni di frequenza, etc.) tra enti di istruzione superiore pone numerose sfide in termini di sicurezza, privacy, interoperabilità e revocabilità. I meccanismi attualmente adottati si basano spesso su scambi manuali o su sistemi centralizzati che:

- richiedono la fiducia in autorità centrali per la verifica delle credenziali;
- non garantiscono la privacy dello studente, che spesso è costretto a rivelare più informazioni del necessario;
- non prevedono una gestione chiara e decentralizzata della revoca delle credenziali;
- risultano poco scalabili e difficilmente interoperabili tra i diversi sistemi nazionali e universitari

Nel frattempo, tecnologie emergenti offrono nuove opportunità per progettare meccanismi di rilascio, presentazione e revoca delle credenziali che siano:

- decentralizzati e resistenti alla censura;
- privacy-preserving, grazie a tecniche di divulgazione selettiva;
- interoperabili tra istituzioni diverse, anche in ambito transnazionale;
- in grado di supportare dinamiche di revoca robuste e verificabili pubblicamente.

Esempio. Si consideri il caso di uno studente iscritto al corso di laurea magistrale in Ingegneria Informatica presso l'Università di Salerno che partecipa a un periodo di mobilità Erasmus presso l'Università di Rennes. Durante la fase di riconoscimento degli esami sostenuti all'estero, lo studente deve dimostrare di aver completato con successo solo specifici insegnamenti presso l'università ospitante. In un sistema tradizionale, ciò comporta l'invio di documenti firmati o certificati digitali tramite canali centralizzati e spesso non interoperabili. La Figura 1 fornisce una visione di alto livello dello scambio di credenziali. Utilizzando invece un meccanismo basato su credenziali digitali accademiche, l'Università di Rennes può rilasciare una credenziale che attesta il superamento di un determinato esame. Lo studente può quindi presentare all'Università di Salerno una versione della credenziale contenente solo le informazioni strettamente necessarie, preservando la propria privacy grazie a tecniche di divulgazione selettiva. Ad esempio, lo studente non dovrà rivelare le attività facoltative a cui ha preso parte. Inoltre, qualora la credenziale venisse revocata (es. per errore amministrativo), l'Università di Salerno potrebbe verificarne la validità.

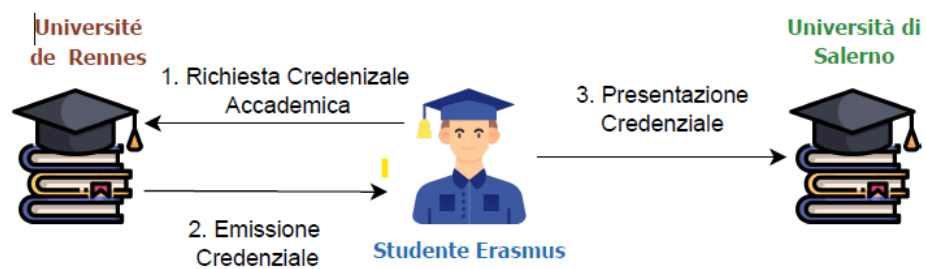


Figura 1: Condivisione selettiva di credenziali accademiche tra Université de Rennes e Università di Salerno

2 WP1: Modello

Il problema che si vuole affrontare riguarda la gestione di un sistema che permetta la condivisione di credenziali. In particolare, consideriamo una situazione in cui uno studente, iscritto all'Università di Salerno, decide di trascorrere un periodo di Erasmus presso l'Università di Rennes dove deve sostenere un numero determinato di esami obbligatori e vuole frequentare altre attività extracurricolari. L'Università di Rennes, per riconoscere allo studente il superamento degli esami che ha sostenuto presso la propria università, deve rilasciargli un certificato che attesti il superamento degli stessi. Lo studente, quindi, deve consegnare questo certificato all'Università di Salerno che deve verificare la validità del certificato e, quindi, aggiungere al libretto dello studente i suddetti esami.

2.1 Definizione degli Attori Onesti

Gli attori coinvolti nel sistema sono i seguenti:

1. **Studente Erasmus;**
2. **Università di Salerno;**
3. **Università di Rennes;**
4. **Autorità di Certificazione;**

2.1.1 Studente Erasmus

Lo **Studente Erasmus** è lo studente che ha aderito al programma Erasmus e intende sostenere o ha sostenuto esami presso un'università diversa da quella in cui si è immatricolato. Lo studente Erasmus, dopo essersi loggato alla propria area personale, può vedere gli esami sostenuti e chiedere le credenziali accademiche all'università ospitante. Lo studente, inoltre, deve inviare personalmente le credenziali rilasciate dall'Università straniera all'Università di Salerno.

Gli obiettivi dello studente Erasmus sono:

- **Ottenimento certificato accademico valido:** deve richiedere e ricevere una certificazione valida che documenti gli esami superati durante il periodo di Erasmus;
- **Condivisione selettiva dei dati:** lo studente vuole presentare solo le informazioni pertinenti per la convalida, tutelando la propria privacy;
- **Dimostrare la validità delle proprie credenziali:** allo studente deve essere garantito che i certificati che gli vengono forniti sono autentici, verificabili e non alterabili.

2.1.2 Università di Salerno

L'**Università di Salerno** è l'università presso cui lo studente è immatricolato. In particolare, deve ricevere le credenziali dallo Studente Erasmus, verificare che queste appartengano all'Università di Rennes, convalidarle e aggiungere gli esami che lo studente Erasmus ha svolto all'estero nel proprio libretto.

Gli obiettivi dell'Università di Salerno sono:

- **Verifica delle certificazioni:** deve verificare che il certificato conferito dallo studente provenga innanzitutto dall'università che ha ospitato lo studente, e che esso non sia stato alterato;
- **Decisione sulla convalida:** una volta ottenuto il certificato, deve riconoscere allo studente gli esami sostenuti all'estero;
- **Tutela dei dati dello studente:** archivia le informazioni ottenute in modo sicuro;

2.1.3 Università di Rennes

L'**Università di Rennes**, ovvero l'università presso la quale lo studente Erasmus sostiene gli esami e che ha il compito di rilasciare la certificazione che attesti che egli ha superato determinati esami con determinati voti. Gli obiettivi dell'Università di Rennes sono:

- **Rilascio di credenziali firmate e verificabili:** l'università deve essere in grado di emettere attestazioni accademiche sotto forma di credenziali verificabili, firmate digitalmente;
- **Supporto alla privacy dello studente:** l'università deve fornire delle metodologie attraverso il quale lo studente non deve divulgare completamente i propri dati al fine di accertare il superamento di un determinato esame;
- **Supporto alla revoca trasparente:** l'università deve pubblicare lo stato delle credenziali in registri verificabili;

2.1.4 Autorità di Certificazione

Le **Autorità di Certificazione** garantiscono l'interoperabilità, la fiducia e la trasparenza all'interno del sistema delle credenziali accademiche. Gli obiettivi delle Autorità di Certificazione sono:

- **Gestione delle identità istituzionali:** consentono alle università di pubblicare e mantenere in modo verificabile le proprie identità;
- **Verifica delle credenziali:** permettono a qualsiasi attore del sistema di verificare l'autenticità di una credenziale, la firma digitale dell'emittente e lo stato di validità;
- **Trasparenza:** ogni operazione pubblicata su queste infrastrutture (es. rilascio, aggiornamento o revoca di una credenziale) è immutabile, tracciabile e accessibile a tutte le parti autorizzate.

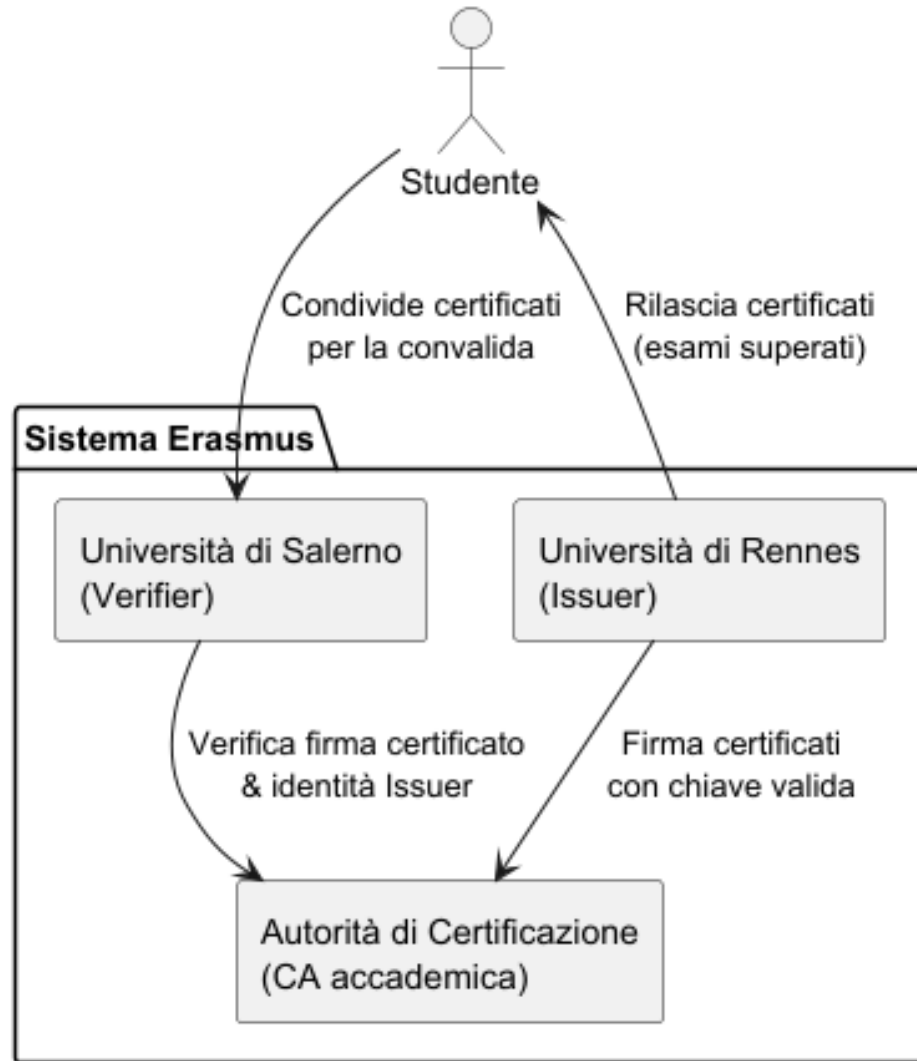


Figura 2: Schema riassuntivo delle relazioni tra gli attori onesti

2.2 Threat Model

Il problema della gestione delle credenziali universitarie di uno studente può attirare l'attenzione di molti possibili avversari. In particolare, i possibili attaccanti identificati sono:

1. Studente disonesto;
2. Funzionario interno malevolo;
3. Ingegnere sociale;
4. Intercettatore;
5. Cacciatore di Vulnerabilità;

2.2.1 Lo Studente Disonesto

Lo **Studente Disonesto** è uno studente che vuole ottenere dei vantaggi accademici (miglioramento del proprio voto, aggiunta di esami non realmente sostenuti, etc...) manipolando il sistema. Le risorse che ha a disposizione sono:

- Accesso alle proprie credenziali digitali o ai file certificati;
- Conoscenza di base su formati digitali e strutture di attestazione;
- Eventuale collaborazione con altri attori;

I suoi obiettivi sono:

- **Alterazione delle credenziali ricevute:** modificare localmente un certificato accademico per aggiungere esami, cambiare voti o date.
- **Falsificazione dell'identità dell'issuer:** simulare che una credenziale sia stata rilasciata da un'università legittima;
- **Inganno del verifier:** presentare credenziali manipolate all'università di origine nella speranza che vengano accettate come autentiche.
- **Elusione dei controlli:** sfruttare falle nei meccanismi di verifica (es. mancata validazione della firma digitale, sistemi di verifica offline).

2.2.2 Il Funzionario Interno Malevolo

Il **Funzionario Interno Malevolo** è un operatore all'interno dell'università (sia di origine che ospitante) che abusa delle proprie risorse per alterare, emettere o revocare credenziali in modo fraudolento.

Le risorse che ha a disposizione sono:

- Accesso ai sistemi informatici istituzionali;
- Conoscenza dei protocolli accademici e dei meccanismi di verifica;
- Autorizzazioni per operare su certificati o database interni;

I suoi obiettivi sono:

- Emettere certificati falsi a favore di studenti non meritevoli;
- Revocare certificati autentici per ostacolare la mobilità;
- Modificare i dati contenuti nelle attestazioni per scopi personali o su richiesta esterna;

2.2.3 L'Ingegnere Sociale

L'**Ingegnere Sociale** è un attaccante che sfrutta tecniche di manipolazione psicologica per ingannare studenti, amministrativi o tecnici IT, al fine di ottenere accessi o informazioni riservate.

Le risorse che ha a disposizione sono:

- Email, telefonate, piattaforme social per condurre attacchi di phishing e pretexting;
- Informazioni personali raccolte da fonti pubbliche;
- Esperienza nella creazione di scenari credibili per ottenere la fiducia delle vittime;

I suoi obiettivi sono:

- Ottenere accesso alle credenziali accademiche di uno studente;
- Indurre un dipendente universitario a firmare o approvare certificati fraudolenti;
- Compromettere il sistema di verifica simulando una richiesta legittima.

2.2.4 L'Intercettatore

L'**Intercettatore** è un attaccante che intercetta comunicazioni tra studenti e università, con l'obiettivo di sottrarre dati sensibili o alterare i flussi di trasmissione delle credenziali.

Le risorse che ha a disposizione sono:

- Dispositivi per lo sniffing di rete (es. man-in-the-middle);
- Accesso a reti Wi-Fi insicure in ambienti universitari o pubblici;
- Competenze per analizzare traffico cifrato o non protetto;

I suoi obiettivi sono:

- Rubare certificati accademici o identità digitali durante la trasmissione;
- Sfruttare le informazioni intercettate per impersonare lo studente o l'università;
- Alterare le credenziali in transito;

2.2.5 Il Cacciatore di Vulnerabilità

Il **Cacciatore di Vulnerabilità** è un attaccante che esamina il sistema al fine di cercare vulnerabilità per ottenere l'accesso al sistema. Le risorse che ha a disposizione sono:

- Scanner automatici di vulnerabilità;
- Conoscenze Avanzate di Sicurezza per identificare e sfruttare vulnerabilità zero-day.
- Capacità di sviluppo;

I suoi obiettivi sono:

- Accedere ai database certificati;
- Compromettere meccanismi di verifica delle firme digitali;
- Vendere le vulnerabilità sul mercato;

2.3 Proprietà del Sistema

Il Sistema deve garantire le seguenti proprietà:

- **Confidenzialità;**
- **Integrità;**
- **Trasparenza;**
- **Efficienza;**
- **Autenticità**
- **Non Ripudio**

2.3.1 Confidenzialità

Il sistema deve garantire che i dati sensibili degli studenti siano accessibili solo dalle parti autorizzate. Inoltre, come specificato, le informazioni che lo studente deve condividere al fine di permettere all'Università di Salerno di convalidare gli esami sostenuti all'estero devono essere minimizzate. Quindi, lo studente deve condividere solo le informazioni strettamente necessarie, senza divulgare dati sensibili e non necessari. È necessario, inoltre, che le informazioni condivise e la comunicazione tra lo studente e l'università siano riservate.

2.3.2 Integrità

Il sistema deve garantire che le credenziali e i certificati dello studente non siano stati manomessi durante la comunicazione.

2.3.3 Autenticità

L'Università di Salerno, che si occupa di verificare che il certificato mostrato dallo studente circa il superamento degli esami sostenuti all'estero, deve accertarsi che il certificato provenga realmente da un'università legittima.

2.3.4 Trasparenza

Il sistema deve essere trasparente, ovvero non deve utilizzare meccanismi di crittografia non conosciuti. In particolare, deve usare algoritmi di crittografia standard e pubblici, al fine di garantire la fiducia che gli studenti e le università ripongono nel sistema. Inoltre, deve essere minimizzato il coinvolgimento di terze parti, rendendo la verifica possibile anche in assenza di un'autorità centrale.

2.3.5 Efficienza

Il sistema deve garantire che tutte le funzionalità ad esso associate avvengano in modo rapido e che sia in grado di gestire tanti utenti nello stesso momento.

2.3.6 Non Ripudio

Il sistema deve garantire che deve essere impossibile per qualsiasi attore del sistema negare di aver compiuto un'azione che ha effettivamente eseguito. Questa proprietà è fondamentale nel contesto accademico per assicurare responsabilità e trasparenza nelle operazioni.

2.4 Struttura delle Credenziali

Una credenziale non è altro che un'attestazione digitale, rilasciata da un'entità autorizzata (Issuer, ovvero l'Università di Salerno). In particolare, essa ha il compito di rendere verificabile uno o più attributi relativi a un soggetto (lo Studente Erasmus).

La lista di attributi che sono stati ritenuti necessari al fine di attestare in modo univoco il superamento di un esame sono:

- `credential_id`: identificatore univoco globale della credenziale;
- `issuer_university`: università che emette la credenziale;
- `issued_date`: timestamp in cui la credenziale è stata firmata;
- `student_info`: informazioni circa lo studente:
 - `student_id`: ID univoco dello studente;
 - `full_name`: nome e cognome dello studente;
 - `email`: email istituzionale dello studente;
 - `home_university`: università di appartenenza dello studente;
- `academic_data`: dati relativi agli esami sostenuti:
 - `academic_year`: anno accademico di emissione della credenziale;
 - `semester`: semestre corrente di emissione della credenziale;
 - `erasmus_program`: flag per verificare se lo studente ha trascorso un periodo di Erasmus;
 - `exams`: struttura contenente gli esami sostenuti all'estero:
 - * `course_name`: nome del corso dell'esame sostenuto;
 - * `course_code`: codice del corso dell'esame sostenuto;
 - * `ects_credits`: numero crediti dell'esame sostenuto;
 - * `grade`: voto dell'esame sostenuto;
 - * `exam_date`: data in cui si è sostenuto l'esame;
 - `total_ects`: numero totale di crediti;
- `digital_signature`, ovvero la firma digitale dell'università emittente;

3 WP2: Soluzione

3.1 Introduzione

Nel seguente Work Package, verrà illustrata la soluzione proposta per il soddisfacimento di tutte le specifiche richieste e proprietà di sicurezza identificate nel WP1. La soluzione è progettata per raggiungere un ragionevole compromesso tra efficienza, trasparenza, confidenzialità e sicurezza nel contesto della condivisione di credenziali accademiche.

Innanzitutto, poiché è necessario che gli attori si autenticino, bisogna mostrare i diversi processi di autenticazione per ogni attore sulla base del ruolo svolto.

Successivamente, nel secondo paragrafo si andrà a fornire una panoramica generale circa il processo di funzionamento della soluzione, andando innanzitutto a illustrare il ruolo svolto dagli attori onesti.

Nel paragrafo successivo, invece, si andranno a specificare, per ciascuna fase, i protocolli crittografici necessari, specificando gli algoritmi utilizzati e le tecniche per garantire le proprietà di sicurezza richieste. Particolare attenzione viene dedicata ai meccanismi di condivisione selettiva, che permettono agli studenti di rivelare solo le informazioni strettamente necessarie, e al sistema di revoca delle credenziali, progettato per essere efficiente e decentralizzato.

Al fine di una maggiore comprensione, viene riportata di seguito una tabella contenente tutti gli attori onesti del sistema, la corrispondente sigla e altri nomi con cui sono indicati nella relazione.

Attore Onesto	Sinonimi	Sigla
Studente Erasmus	Studente	S
Università di Rennes	Università ospitante, Issuer	UoR
Università di Salerno	Università di Appartenenza, Verifier, Università di Origine	UoS
Certificate Authority	-	CA

Tabella 1: Attori Onesti e relativi Sinonimi e sigla utilizzati

3.2 Processo di Autenticazione degli Attori Onesti

Prima di definire il meccanismo di funzionamento del sistema, è necessario andare a definire i metodi di autenticazione di ogni attore onesto. In particolare, si definisce l'insieme delle tecnologie utilizzate al fine di permettere agli attori onesti di autenticarsi come tali, fornendo una panoramica di ogni metodologia utilizzata.

3.2.1 Fast Identity Online 2 (FIDO2)

FIDO2 (Fast Identity Online 2) è uno standard aperto per l'autenticazione sviluppato da Fido Alliance che mira ad eliminare la dipendenza da password tradizionali. FIDO2 si basa su due specifiche tecniche fondamentali: **WebAuthn** e **CTAP2**:

- **WebAuthn (Web Authentication)** è un'API web standardizzata dal W3C che permette ai siti web di utilizzare autenticatori FIDO per l'autenticazione degli utenti;
- **CTAP2 (Client to Authenticator Protocol 2)** è il protocollo che gestisce la comunicazione tra dispositivi client (computer e smartphone) e autenticatori esterni come chiavi di sicurezza USB, NFC o Bluetooth.

Il processo di autenticazione si basa sulla crittografia a **chiave pubblica**. Durante la registrazione, l'autenticatore genera una coppia di chiavi crittografiche unica per ogni servizio. La chiave rimane sempre protetta dall'autenticatore e non viene mai trasmessa, mentre la chiave pubblica viene registrata presso il servizio online. Durante la fase di login, il servizio invia all'utente una challenge crittografica che l'autenticatore risolve utilizzando la chiave privata corrispondente. L'utente conferma, quindi, la propria identità tramite un gesto biometrico (impronta digitale, riconoscimento facciale) oppure inserendo un PIN. Gli autenticatori possono essere di diversi tipi:

- **Autenticatori esterni:** includono chiavi di sicurezza fisiche collegabili tramite USB, NFC o Bluetooth. Il vantaggio di questo approccio è che isolano completamente le credenziali dal dispositivo digitale;
- **Autenticatori integrati:** dispositivi built-in nei dispositivi moderni, come sensori biometrici degli smartphone, Windows Hello, TouchID.

Durante la fase di autenticazione, i parametri di registrazione necessari sono:

- **Challenge:** stringa casuale di byte, utilizzata per prevenire attacchi replay;
- **rpID:** identifica il dominio del RP (es. studenti.unisa.it);
- **User:** ID generato casualmente che viene utilizzato per associare una credenziale con un utente;
- **PubKeyCredParams:** tipi di chiavi pubbliche che sono accettabili per il RP;
- **AuthenticatorSelection:**
 - Il tipo di autenticatore (roaming o platform);
 - Se la chiave privata dell'autenticatore deve essere residente (l'autenticatore memorizza direttamente la chiave privata nel suo storage interno);
 - Se la verifica dell'utente è richiesta, preferita o sconsigliata;
- **Timeout:** il tempo entro cui l'utente deve rispondere; altrimenti si verifica un errore;
- **Attestation:** permette al RP di specificare se sono richiesti dati di attestazione. Consente al RP di verificare la veridicità e la sicurezza dell'autenticatore utilizzato;

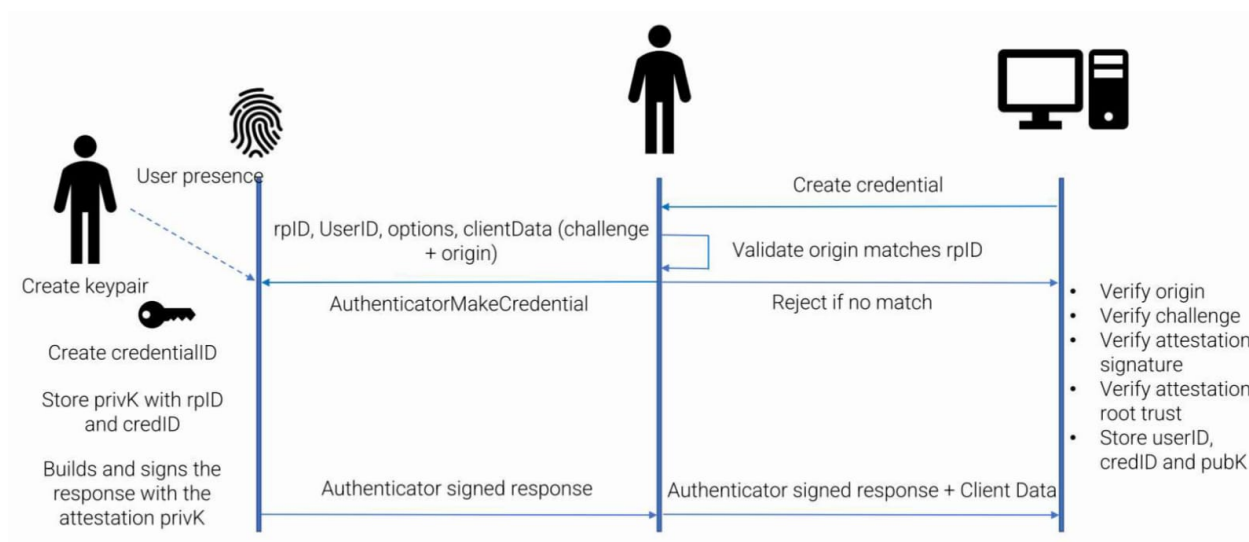


Figura 3: Cerimonie di Registrazione di FIDO2

3.2.2 MultiFactor Authentication (MFA)

L'**Autenticazione Multifattore (MFA)** è un meccanismo di sicurezza che richiede la combinazione di due o più fattori di autenticazione indipendenti per verificare l'identità di un utente. La rilevanza strategica di questo approccio è testimoniata dal fatto che l'implementazione dell'MFA elimina il 99.9% degli accessi non autorizzati che utilizzano password compromesse, fornendo quindi un livello di protezione significativamente superiore rispetto ai tradizionali sistemi basati su singolo fattore.

L'architettura dell'MFA si basa sulla combinazione strategica di diverse categorie di fattori di autenticazione, ciascuna delle quali presenta caratteristiche specifiche in termini di sicurezza, usabilità e modalità di implementazione. La classificazione tradizionale identifica quattro categorie principali di fattori autenticativi:

- **Knowledge Factor:** comprende tutti quegli elementi che l'utente conosce, come password, PIN, passphrase o risposte a domande di sicurezza;
- **Possession Factor:** include dispositivi fisici o digitali che l'utente possiede, quali smart card, token hardware, smartphone con applicazioni authenticator o certificati digitali;
- **Inherence Factor:** si basa su caratteristiche fisiche uniche dell'individuo, come impronte digitali, riconoscimento facciale, scansione dell'iride o geometria della mano;
- **Behavior Factor:** analizza modelli comportamentali specifici dell'utente, come il ritmo di digitazione, i pattern di movimento del mouse o le caratteristiche vocali;

Dal punto di vista implementativo, l'MFA può essere realizzato attraverso diverse tecnologie, ciascuna con specifiche caratteristiche di sicurezza e usabilità. Le implementazioni più comuni nel contesto accademico includono sistemi basati su SMS, che inviano codici OTP (One-Time Password) al dispositivo mobile dell'utente, offrendo universalità di supporto ma

mostrando vulnerabilità agli attacchi di SIM swapping e man-in-the-middle. Un approccio più robusto è rappresentato dalle applicazioni authenticator basate su algoritmi **TOTP (Time-based One-Time Password)**, come Google Authenticator o Authy, che generano codici temporizzati utilizzando algoritmi crittografici standardizzati. Questi sistemi operano offline, riducendo la superficie di attacco, ma richiedono sincronizzazione temporale accurata tra client e server.

Le soluzioni più avanzate includono push notifications context-aware, che inviano notifiche di approvazione direttamente su dispositivi registrati, offrendo un'esperienza utente ottimale ma richiedendo connettività costante. Al vertice della scala di sicurezza si collocano i token hardware conformi agli standard FIDO2/WebAuthn, che offrono resistenza completa agli attacchi di phishing ma comportano costi di implementazione e complessità gestionale superiori.

3.2.3 Studente Erasmus

Lo Studente Erasmus ha a disposizione un **Wallet Digitale**, ovvero un sistema che funge da "contenitore sicuro" per le identità digitali e le credenziali di un utente. Analogamente a un portafoglio fisico che contiene carte di identità, tessere e denaro, un Wallet Digitale memorizza:

- Chiavi pubbliche associate ai meccanismi di autenticazione;
- Certificati digitali firmati dalle Università;
- Token di autenticazione temporanei;
- Metadati associati alle credenziali;

Per l'autenticazione, è adottato un sistema **FIDO2/WebAuthn**, che consente allo studente di autenticarsi utilizzando un authenticator sicuro (come uno smartphone, una chiavetta o un TPM). Questo dispositivo custodisce localmente e in modo protetto la chiave privata, che non lascia mai l'hardware. La chiave pubblica corrispondente viene invece memorizzata dal server universitario e, opzionalmente, anche nel Wallet per verifica e interoperabilità.

Come metodo di sblocco del dispositivo di autenticazione, lo studente può usare un **metodo biometrico** (es. impronta digitale o Face ID) o, in caso di indisponibilità, un **PIN di fallback** previsto dallo standard FIDO2. In caso di smarrimento del dispositivo, è prevista una procedura di recupero dell'account articolata in due modalità:

- **In presenza:**
 - Identificazione con documento fisico;
 - Verifica dati anagrafici;
 - Reset assistito con nuovo dispositivo;
- **Da remoto:**
 - Videocall di identificazione;

- Verifica multi-canale (email/SMS);
- Generazione link di reset sicuro;

La fase di **Registrazione dello Studente** è necessaria affinché ciascuna università possa riconoscere e interagire con lo studente attraverso meccanismi sicuri di autenticazione e rilascio credenziali. Lo studente conserva un **unico Wallet Digitale personale**, che funge da contenitore sicuro per le credenziali accademiche ricevute da più istituzioni. Ciascuna università crea un proprio profilo locale associato all'identità dello studente e ne registra l'autenticatore FIDO2.

I due processi distinti sono:

- **Registrazione presso l'Università di Origine:** avviene al momento dell'iscrizione e permette allo studente di autenticarsi sul portale dell'ateneo, ricevere credenziali accademiche e gestire il proprio profilo;
- **Registrazione presso l'Università Ospitante:** avviene all'inizio del soggiorno Erasmus e consente l'accesso ai servizi dell'ateneo estero, oltre al rilascio di nuove credenziali digitali per esami svolti durante il periodo Erasmus.

Entrambe le università agiscono come **Relying Party FIDO2**, ciascuna con un proprio dominio. Durante la registrazione:

- l'autenticatore FIDO2 dello studente genera una coppia di chiavi pubblica/privata distinta per ciascun dominio universitario;
- la chiave pubblica viene inviata e memorizzata dal server universitario, legandola all'identità dello studente;
- la chiave privata resta protetta all'interno del dispositivo dell'utente (es. smartphone o security key) e non viene mai esposta.

Lo studente utilizza quindi lo stesso autenticatore FIDO2 per accedere in modo sicuro ai portali dell'Università di Origine e di quella Ospitante, ma attraverso meccanismi crittografici distinti per ciascuna istituzione.

L'autenticazione FIDO2 serve per dimostrare la propria identità verso i server universitari e ottenere l'accesso ai portali, da cui lo studente può ricevere o aggiornare le proprie credenziali da inserire nel Wallet Digitale.

Si divide in diverse fasi:

1. **Enrollment dello Studente:**

- (a) **Identificazione iniziale:** lo studente si presenta fisicamente o tramite procedure di identificazione sicure presso l'università;
- (b) **Binding dell'Authenticator:** Il sistema associa le credenziali FIDO2 del dispositivo dello studente al suo profilo accademico;
- (c) **Configurazione del fallback PIN:** Viene impostato un PIN di backup per situazioni in cui il biometrico non fosse disponibile;

2. Processo di Registrazione FIDO2:

- (a) **Richiesta di registrazione:** Il server dell'università (Relying Party) invia una challenge di registrazione;
- (b) **Interazione utente:** Lo studente conferma tramite biometrico o PIN sul proprio dispositivo;
- (c) **Generazione chiavi:** L'authenticator genera una coppia di chiavi pubblica/privata specifica per l'università;
- (d) **Attestation:** Il dispositivo fornisce un'attestazione della sua autenticità;
- (e) **Memorizzazione:** Il server memorizza la chiave pubblica associandola all'identità dello studente.

Una volta effettuata la registrazione, lo studente può effettuare l'**Autenticazione**, che si divide in:

1. Avvio del Processo di Login

- (a) **Accesso al portale:** Lo studente accede al portale dell'Università appropriata:
 - Università di Origine per gestire il proprio profilo;
 - Università Ospitante per richiedere credenziali accademiche;
- (b) **Identificazione:** Inserisce il proprio StudentID o utilizza un identificativo univoco;
- (c) **Richiesta autenticazione:** Il sistema riconosce che lo studente ha FIDO2 configurato;

2. Flusso FIDO2 Challenge-Response

- (a) **Challenge generation:** Il server genera una challenge crittografica univoca e temporizzata;
- (b) **Presentazione al client:** Il browser riceve la challenge e la presenta all'authenticator;
- (c) **User verification:** Lo studente si autentica tramite un processo biometrico primario (impronta digitale, Face ID, ecc.) oppure PIN fallback (se il biometrico fallisce o non è disponibile);
- (d) **Signature generation:** L'authenticator firma la challenge con la chiave privata dello studente;
- (e) **Response verification:** Il server verifica la firma utilizzando la chiave pubblica memorizzata;

Se la procedura di autenticazione è andata a buon fine, l'utente entra nella **Sessione Autenticata**. Le funzionalità disponibili dipendono dall'Università a cui si accede:

1. Università di Salerno

- Visualizzare esami sostenuti;
- Verificare stato di validità delle credenziali;

2. Università di Rennes:

- Visualizzare esami sostenuti durante il periodo Erasmus;
- Richiedere credenziali per esami sostenuti all'estero;
- Selezione di quali informazioni includere nelle credenziali per esami sostenuti durante il periodo Erasmus;
- Verificare stato delle credenziali emesse da Rennes;

3.2.4 Università di Rennes e di Salerno

A differenza dello studente Erasmus, un impiegato che espleta le sue funzioni presso un'università ricopre un ruolo critico, a causa dei privilegi a esso concessi. Proprio per questo motivo, la fase di autenticazione rappresenta un punto cruciale. L'approccio implementato per il personale universitario si basa su una strategia di **autenticazione adattiva**, che seleziona automaticamente il metodo più appropriato in base alle capacità del dispositivo utilizzato, al contesto di accesso e al profilo di rischio dell'operazione richiesta.

Quando disponibile e correttamente configurato, il sistema privilegia l'utilizzo di **FIDO2/WebAuthn**. Tuttavia, poiché non tutti i dispositivi supportano tale tecnologia o potrebbero verificarsi situazioni in cui FIDO2 non è accessibile, è previsto un meccanismo di **fallback** basato su **autenticazione multifattore (MFA)** tradizionale. Quest'ultima combina l'uso di password robuste con codici temporanei TOTP (Time-based One-Time Password) generati da applicazioni Authenticator.

Il processo di autenticazione tramite FIDO2 segue lo stesso schema già descritto per lo studente Erasmus. Di seguito vengono invece elencate le fasi necessarie affinché un funzionario dell'università possa accedere alla propria area riservata tramite il meccanismo MFA.

Enrollment e Configurazione Iniziale

1. Onboarding del Personale:

- (a) **Verifica identità istituzionale:** Il dipartimento conferma l'identità e il ruolo del dipendente;
- (b) **Assegnazione privilegi:** I permessi vengono definiti in base al ruolo (amministrativo, docente, tecnico IT);
- (c) **Setup Password:** Impostazione di una password conforme alle policy di sicurezza universitarie;
- (d) **Configurazione TOTP:** Registrazione dell'app Authenticator sul dispositivo personale del funzionario;
- (e) **Generazione backup codes:** Creazione di codici di recupero numerici, temporizzati e validi per un periodo limitato;

- (f) **Verifica SMS:** Registrazione di un numero telefonico per l'invio di codici di emergenza.

2. Configurazione Multi-Device:

- (a) **Dispositivo principale:** Stazione di lavoro in ufficio, abilitata FIDO2/WebAuthn;
- (b) **Dispositivo mobile:** Smartphone con app TOTP per l'autenticazione da remoto;
- (c) **Dispositivi secondari:** Laptop personale per attività in smartworking o mobilità.

Autenticazione Standard – Accesso via MFA

1. Accesso di Routine:

- (a) **Identificazione:** Inserimento delle credenziali istituzionali (username e password);
- (b) **Primo Fattore:** Validazione delle credenziali da parte del sistema;
- (c) **Valutazione del rischio:** Analisi di fattori contestuali (IP, dispositivo, orario, geolocalizzazione);
- (d) **Richiesta secondo fattore:** Inserimento del codice TOTP generato dall'app Authenticator.

Meccanismo TOTP – Funzionamento TOTP (Time-based One-Time Password) è un algoritmo standardizzato per la generazione di password temporanee basate sul tempo, come definito dalla specifica RFC 6238. Si tratta di un meccanismo che produce codici numerici monouso, validi per un intervallo temporale breve (tipicamente 30 secondi), utilizzando una combinazione tra una chiave segreta condivisa e il timestamp corrente.

Il processo di validazione TOTP si articola come segue:

1. **Generazione codice:** L'app Authenticator genera un codice valido per 30 secondi;
2. **Inserimento:** Il funzionario inserisce il codice nel portale di login;
3. **Validazione server:** Il backend dell'università verifica il codice tramite algoritmo HMAC-SHA1;
4. **Time Window:** È accettato un piccolo margine di tolleranza temporale per compensare eventuali desincronizzazioni;
5. **Anti-Replay:** Il sistema impedisce il riutilizzo dello stesso codice già accettato.

3.2.5 Certificate Authority

L'Autorità di Certificazione (CA) rappresenta il pilastro fondamentale della fiducia digitale nell'intero ecosistema del sistema Erasmus per la gestione delle credenziali accademiche. Essa è responsabile della firma, emissione e revoca dei certificati digitali associati alle credenziali

rilasciate dalle università partecipanti.

Per garantire la massima sicurezza operativa e la resilienza del sistema, anche per gli amministratori della CA è stato adottato un approccio di **autenticazione ibrida**, basato su:

- **FIDO2/WebAuthn** come meccanismo primario;
- **MFA tradizionale** (password + TOTP) come fallback in casi eccezionali.

La differenza sostanziale rispetto ai flussi descritti nei paragrafi precedenti riguarda il livello di protezione richiesto: per gli amministratori della CA, l'utilizzo di **Hardware Security Keys** conformi agli standard FIDO2/WebAuthn è **obbligatorio**.

Questi dispositivi, progettati per offrire un livello di sicurezza avanzato, sono fisicamente tamper-resistant e custodiscono internamente le chiavi crittografiche in modalità **non estraibile**. In tal modo:

- è impedita la clonazione o esportazione delle chiavi private;
- viene garantita la firma delle challenge direttamente nel dispositivo hardware;
- si riduce drasticamente il rischio di compromissione dell'identità digitale dell'amministratore.

Grazie all'utilizzo delle Hardware Security Keys, ogni operazione sensibile svolta dagli amministratori della CA — come la generazione o revoca di certificati — avviene all'interno di un perimetro di massima affidabilità, rafforzando la fiducia nell'intero sistema.

3.3 Funzionamento generale del sistema

In questo paragrafo verrà illustrato il funzionamento generale del sistema, in particolare l'insieme delle fasi necessarie affinché uno studente sia in grado di richiedere delle credenziali all'Università ospitante e mostrarle all'Università di appartenenza, al fine di farsi riconoscere il superamento degli esami sostenuti.

Il sistema si basa su un'architettura ibrida che combina una Certificate Authority (CA) centralizzata per l'accreditamento iniziale con una blockchain Ethereum decentralizzata per la gestione operativa delle credenziali. Uno smart contract centrale orchestra tutte le operazioni mantenendo tre registri interconnessi: università accreditate, credenziali emesse e stati di revoca.

Va sottolineato che in questo paragrafo verrà presentato solo il meccanismo di funzionamento del sistema, senza menzionare aspetti tecnici e teorici, che saranno sviluppati nei paragrafi successivi. Le fasi necessarie per raggiungere questo obiettivo sono:

1. Accredimento delle Università;
2. Generazione delle Credenziali;
3. Presentazione Selettiva delle Credenziali;

A queste fasi è necessario aggiungere anche un altro meccanismo, che è quello di **revoca**, al fine di permettere l'invalidazione di credenziali compromesse, errate o fraudolente, mantenendo l'efficienza del sistema e la privacy degli studenti.

3.3.1 Accredimento delle Università

Si definisce **accredimento delle università** il processo attraverso il quale un'università assume le capacità crittografiche necessarie all'emissione di credenziali digitali. In particolare, l'obiettivo è quello di stabilire una relazione di fiducia tra la CA e le università partecipanti, fornendo a queste ultime gli strumenti crittografici per operare nel sistema. Il **processo di accredimento** si articola nelle seguenti fasi:

1. **Richiesta di accredimento:** L'università invia alla CA una richiesta formale, dove deve includere una documentazione istituzionale e identificativi ufficiali; quando un'università presenta documentazione insufficiente o non valida, il sistema fornisce un feedback dettagliato e costruttivo, specificando esattamente quali documenti mancano o non sono conformi agli standard richiesti.
2. **Verifica dell'identità:** Qualora la richiesta di accredimento fosse andata a buon fine, la CA verifica l'autenticità e la legittimità dell'università attraverso dei controlli amministrativi;
3. **Generazione delle chiavi:** L'università genera una coppia di chiavi crittografiche, una pubblica e una privata;
4. **Certificate Signing Request (CSR):** L'Università definisce un messaggio crittografico per richiedere l'emissione del certificato digitale. Vengono inclusi la chiave pubblica generata al passo precedente e i metadati istituzionali, firmata con la chiave privata per dimostrare il possesso;

5. **Rilascio del certificato digitale:** La CA verifica la CSR e, qualora esso rispettasse tutte le condizioni, emette un certificato digitale X.509v3 che attesta l'identità dell'università e la sua autorizzazione a emettere credenziali accademiche;
6. **Pubblicazione:** Il certificato dell'università deve essere pubblicato in una repository accessibile per la verifica, garantendo trasparenza.
7. **Memorizzazione del certificato:** Una volta emesso il certificato in favore dell'Università che ne aveva fatto richiesta, questo deve essere memorizzato. La metodologia di memorizzazione del certificato può essere sia fisica sia decentralizzata. La registrazione fisica del certificato presenta molte limitazioni. Innanzitutto, si hanno molte restrizioni dal punto di vista fisico: rischi di deterioramento, perdita accidentale o disintegrazione. Inoltre, deve essere archiviato in infrastrutture in cui è necessaria l'assunzione di personale dedicato. Poiché il nostro focus è l'interoperabilità delle Università, in questo modo il processo di verifica risulta essere estremamente lento. Per questi motivi, si è deciso di utilizzare un registro decentralizzato, implementato per mezzo di una **Blockchain**. In particolare, questa metodologia assicura che ogni operazione (rilascio, aggiornamento o revoca) venga registrata in modo permanente e verificabile. Dal punto di vista dell'interoperabilità, il vantaggio offerto da questa tecnologia è che tutte le istituzioni partecipanti possono accedere alle stesse informazioni utilizzando protocolli standardizzati, eliminando, quindi, le barriere tecniche e burocratiche.

3.3.2 Generazione delle Credenziali

Si definisce **generazione delle credenziali** il processo attraverso cui uno studente richiede e ottiene le credenziali accademiche da presentare alla propria Università di appartenenza. Questo processo si articola in più fasi:

1. **Richiesta della Credenziale:** Lo studente, dopo aver effettuato l'accesso alla propria area personale utilizzando le proprie credenziali richiede l'emissione di una specifica credenziale accademica, selezionando gli esami specifici per cui richiede la certificazione;
2. **Verifica e Validazione della Richiesta:** L'Università, una volta ricevuta la richiesta da parte dello studente, procede con la fase di verifica. In particolare, un funzionario dell'Università di Rennes verifica la correttezza della richiesta e la completezza dei dati accademici. La validazione degli esami avviene in modo automatico tramite l'accesso al sistema informativo accademico, che rappresenta la fonte ufficiale del libretto dello studente. Solo gli esami effettivamente registrati nel database possono essere inclusi nella credenziale, impedendo l'inserimento di esami mai realmente sostenuti dallo studente;
3. **Generazione delle Credenziali:** Qualora il processo di verifica fosse andato a buon fine, l'Ufficio preposto procede con la generazione delle credenziali, ovvero con la costruzione del Merkle Tree contenente tutti i campi della credenziale e la consegna della credenziale completa e della struttura dell'albero al Wallet dello studente, abilitando così la futura divulgazione selettiva;

4. **Firma Digitale e Autenticazione:** Le credenziali vengono firmate digitalmente dall'Università Ospitante utilizzando il certificato generato nel paragrafo precedente. Questo passaggio è necessario affinché le credenziali siano verificabili da parti terze;
5. **Memorizzazione delle Credenziali:** Simultaneamente alla consegna allo studente, l'università registra la credenziale sulla blockchain Ethereum. Lo smart contract memorizza:
 - **Merkle Root** dell'albero contenente tutti i campi della credenziale;
 - **Metadati essenziali:** identificativo credenziale, università emittente, timestamp;
 - **Stato iniziale:** "ACTIVE";

Questa registrazione è **fondamentale per abilitare le future verifiche indipendenti** senza necessità di contattare l'università emittente.

3.3.3 Presentazione Selettiva delle Credenziali

Una volta che lo studente ha ricevuto le credenziali da parte dell'Università Ospitante, egli deve presentarle all'Università di Appartenenza al fine di farsi convalidare gli esami svolti all'estero. In questa fase, è necessario che lo studente possa effettuare una **presentazione selettiva delle credenziali**, ovvero deve poter inserire all'interno delle credenziali solo le informazioni strettamente necessarie, omettendo quindi le informazioni che non occorrono alla convalida degli esami sostenuti all'estero. La presentazione selettiva delle credenziali è costituita dalle seguenti fasi:

1. **Richiesta di Presentazione:** Lo studente contatta la propria Università di appartenenza, chiedendo quali sono gli attributi strettamente necessari da includere nella credenziali;
2. **Selezione degli Attributi:** Lo studente seleziona i campi specifici della credenziale che deve condividere con l'Università, mantenendo quindi privati gli altri;
3. **Presentazione della Prova:** Lo studente genera automaticamente le prove crittografiche di inclusione (Merkle proof) per i campi selezionati e trasmette solo questi campi insieme alle prove, senza rivelare i campi omessi, utilizzando un canale sicuro (TLS);
4. **Verifica della Prova:** L'Università di appartenenza riceve quindi le credenziali inviate dallo studente. A questo punto, è necessario un processo di verifica. La prima verifica che deve essere fatta riguarda la verifica preliminare dello stato di revoca. Successivamente, l'Università di Salerno deve verificare che le credenziali siano state effettivamente emesse dall'Università di Rennes, validando la firma RSA-PSS e la verifica del certificato digitale x.509 e che i criteri di accettazione della credenziale siano stati soddisfatti. L'Università interroga lo smart contract sulla blockchain Ethereum per verificare il Merkle Root registrato e lo stato di revoca;
5. **Accettazione dei Dati:** Sulla base delle verifiche fatte al punto precedente, l'Università decide se considerare validi e autentici le credenziali presentate dallo studente.

3.3.4 Meccanismo di Revoca delle Credenziali

Il meccanismo di revoca rappresenta un elemento fondamentale del sistema, necessario per garantire che credenziali compromesse, errate o fraudolente possano essere invalidate tempestivamente, mantenendo al contempo l'efficienza del sistema e la privacy degli studenti. La revoca può essere necessaria in diversi scenari: quando vengono scoperte irregolarità nella documentazione originale, in caso di compromissione delle chiavi crittografiche dell'università emittente, o quando emergono evidenze di frode nella generazione delle credenziali. Il processo di revoca si articola nelle seguenti fasi:

1. **Identificazione della necessità di revoca:** L'Università Emittente identifica la necessità di revocare una o più credenziali specifiche. Questa identificazione può avvenire attraverso controlli interni di qualità, segnalazioni da parte di altre istituzioni, o a seguito di audit di sicurezza che rilevano anomalie;
2. **Richiesta di revoca:** L'università prepara una richiesta formale di revoca che include l'identificativo univoco della credenziale (IDCred), la motivazione della revoca, e la documentazione di supporto che giustifica la decisione. Questa richiesta viene firmata digitalmente utilizzando la chiave privata dell'università per garantire autenticità e non ripudio;
3. **Registrazione sulla Blockchain:** La richiesta di revoca viene registrata sulla blockchain Ethereum tramite lo smart contract, aggiornando lo stato da 'ACTIVE' a 'REVOKED', includendo un timestamp della revoca e la motivazione fornita;
4. **Impatto sulle verifiche future:** Da questo momento in poi, qualsiasi tentativo di presentazione di quella credenziale specifica risulterà in un rifiuto automatico durante la fase di verifica dello stato di revoca, indipendentemente dalla validità delle prove crittografiche;

È importante sottolineare che il meccanismo di revoca opera a livello di singola credenziale e non comporta la compromissione dell'intero sistema o delle altre credenziali emesse dalla stessa università. Inoltre, il processo è progettato per essere trasparente e verificabile, garantendo che le decisioni di revoca siano documentate e giustificate, proteggendo così i diritti degli studenti coinvolti. Il sistema mantiene anche uno storico completo delle revoche, permettendo audit futuri e fornendo evidenze in caso di dispute o controversie. Questo approccio bilancia la necessità di sicurezza del sistema con la tutela della privacy e dei diritti degli individui coinvolti.

3.4 Dettagli Tecnici e Protocolli Utilizzati

Nel seguente capitolo verranno presentate tutte le tecnologie e i sistemi crittografici utilizzati al fine di soddisfare i requisiti definiti nel paragrafo precedente.

3.4.1 Firme Digitali

L'algoritmo scelto per la firma digitale delle credenziali è **RSA-PSS**. Nelle firme digitali, l'approccio è opposto a quello della generazione di chiavi: si utilizza la chiave privata per

firmare il messaggio, e chiunque può usare la chiave pubblica per verificare la firma.

RSA-PSS (Probabilistic Signature Scheme) è un algoritmo basato sull'approccio "hash-and-sign", dove non si va a firmare il messaggio originale, ma una sua trasformazione crittografica tramite funzioni di hash. RSA è uno dei primi e più importanti algoritmi di crittografia a chiave pubblica, basato sulle proprietà dei numeri primi e sui risultati relativi alla teoria dei numeri. RSA si basa sulla funzione **trapdoor unidirezionale**: è facile da calcolare, ma difficile da invertire. Questo principio deriva dalla difficoltà computazionale della fattorizzazione dei numeri grandi.

Il meccanismo di generazione delle chiavi RSA è mostrato di seguito:

1. Scelta di 2 numeri primi: p, q ;
2. Calcolo $N = p \times q$;
3. Calcolo $\varphi(n) = (p - 1)(q - 1)$ (funzione di Eulero)
4. Scelta di e tale che $1 < e < \varphi(N)$ e $\gcd(e, \varphi(N)) = 1$
(e e $\varphi(N)$ sono coprimi)
5. Calcolo di d come inverso moltiplicativo di e :
 $d \equiv e^{-1} \pmod{\varphi(N)}$
6. Chiave pubblica = (e, N)
7. Chiave privata = (d, N)

Affinché la funzione di hash H risulti sicura, devono essere soddisfatte le seguenti proprietà:

- **Resistenza al No-Message Attack**: Deve essere impossibile per un attaccante partire da una firma σ , calcolare $m' = \sigma^e \pmod{N}$, e poi trovare un messaggio m tale che $H(m) = m'$. Questo previene attacchi in cui l'attaccante genera prima la firma e poi cerca un messaggio corrispondente,
- **Assenza di Relazioni Moltiplicative**: Se fosse presente una relazione moltiplicativa, un attaccante potrebbe scegliere m_1 e m_2 tali che $m_1 \cdot m_2 = m \pmod{N}$. In questo modo, ottenendo le firme legittime σ_1 e σ_2 , può calcolare $\sigma = (\sigma_1 * \sigma_2) \pmod{N}$
- **Resistenza alle Collisioni**: Se $H(m_1) = H(m_2)$, allora m_1 e m_2 avranno la stessa firma, rendendo il forgery triviale. Quindi H deve essere collision-resistant.

I componenti fondamentali di questo protocollo sono:

- **Salt**: valore casuale generato per ogni firma;
- **Mask Generation Function (MGF1)**: una funzione deterministica che genera una maschera pseudocasuale di lunghezza arbitraria a partire da un seed di lunghezza fissa;
- **Padding Structured**;

3.4.2 Certificati Digitali

Un **certificato digitale** è un documento elettronico firmato digitalmente che:

- autentica l'identità di una persona, organizzazione o dispositivo;
- Associa una chiave pubblica a quell'identità;
- È firmato da un'autorità fidata (Certificate Authority);

Lo standard a cui facciamo riferimento è lo standard X.509.

3.4.3 Merkle Tree

Un **Merkle Tree** è un albero binario dove le foglie sono blocchi contenenti dati. I blocchi dati sono raggruppati in coppie e l'hash di ciascuno di questi blocchi è memorizzato in un nodo padre ($Padre = H(figlio_{sx} || figlio_{dx})$). I nodi padre sono a loro volta raggruppati in coppie e i loro hash sono memorizzati un livello sopra nell'albero. Questo continua fino a raggiungere il nodo radice.

L'utilizzo dei Merkle Tree risulta essere necessario per il meccanismo di divulgazione selettiva: lo studente, attraverso questo approccio, può decidere di non rivelare alcuni campi delle credenziali che non sono necessari per la convalida degli esami sostenuti all'estero. In particolare, lo studente può quindi rivelare solo i campi necessari. Questo è possibile memorizzando i campi delle credenziali all'interno dei blocchi dati che costituiscono le foglie dell'albero. In questo modo, per provare che un blocco dati è incluso nell'albero, basta mostrare i blocchi nel percorso da quel blocco dati alla radice.

3.4.4 Blockchain e Smart Contract

Una **blockchain** è un sistema di registro decentralizzato che consiste in una catena sequenziale di blocchi collegati crittograficamente. Ogni blocco contiene un insieme di **transazioni**, ovvero un insieme di istruzioni crittograficamente firmate utilizzando la chiave privata dell'account mittente, inviate da esso per aggiornare lo stato della blockchain. Inoltre, ogni blocco è protetto crittograficamente, al fine di garantire l'integrità e l'immutabilità dei dati. Il nostro sistema utilizza la blockchain Ethereum come infrastruttura di base, sfruttando le sue capacità di programmabilità e il supporto per l'utilizzo degli Smart Contract. Nel nostro contesto, Ethereum fornisce:

- **Decentralizzazione:** elimina la necessità di una autorità centrale per la verifica delle credenziali;
- **Immutabilità:** una volta registrate, le credenziali non possono essere alterate senza il consenso della rete;
- **Trasparenza:** tutte le transazioni sono visibili e verificabili da tutti i partecipanti della rete;
- **Resistenza alla censura:** Nessuna singola entità può impedire o modificare transazioni valide;

- **Programmabilità:** Supporto nativo per Smart Contract che automatizza la gestione delle credenziali;

La blockchain Ethereum utilizza degli **hash pointer** per collegare blocchi in sequenza. Ogni blocco contiene.

- Un hash per il controllo precedente;
- un timestamp che indica quando il blocco è stato minato;
- un insieme di transazioni validate;
- un Merkle Root che rappresenta l'hash del Merkle Tree di tutte le transazioni contenute;
- Il nonce utilizzato per il mining;

Uno **Smart Contract** è un programma auto-eseguibile memorizzato sulla blockchain, dove i termini dell'accordo o le regole di esecuzione sono scritte direttamente nel codice. Nel contesto del nostro progetto, gli smart contract automatizzano il processo di gestione e verifica delle credenziali accademiche. Ogni smart contract ha:

- Un indirizzo che lo identifica univocamente sulla blockchain;
- Funzioni che possono essere invocate dall'esterno;
- Uno stato interno che rappresenta i valori delle variabili in un dato momento;

In particolare, il nostro sistema si avvale di un singolo Smart Contract centrale che gestisce l'intero ciclo di vita delle credenziali accademiche, dalla fase di accreditamento delle università fino alla gestione delle revoche. Il sistema mantiene la sua architettura di fiducia basata sulla Certificate Authority accademica, sfruttando i certificati digitali X.509 non solo per la firma delle credenziali, ma anche come meccanismo di controllo degli accessi alla blockchain. Questo approccio garantisce coerenza architetturale: le università che possono firmare credenziali sono esattamente le stesse che possono interagire con lo smart contract. Quando la CA accredita una nuova università rilasciando il certificato X.509, contestualmente registra l'hash di tale certificato sulla blockchain Ethereum attraverso una funzione dedicata dello smart contract. Questo crea un registro decentralizzato delle università autorizzate che serve sia per la verifica delle credenziali che per il controllo degli accessi alle funzionalità blockchain. Quindi, lo smart contract mantiene tre registri principali interconnessi: il registro delle università accreditate, il registro delle credenziali emesse e il registro degli stati di revoca. Questa struttura unificata permette verifiche atomiche e garantisce la coerenza dei dati attraverso l'immutabilità della blockchain. Quando un'università emette una credenziale, lo smart contract memorizza il Merkle Root dell'albero contenente tutti i campi della credenziale, insieme ai metadati essenziali come l'identificativo dell'emittente e il timestamp di emissione. Questo approccio preserva la privacy attraverso la divulgazione selettiva. In particolare, solo l'hash radice è pubblico, mentre i dati specifici rimangono privati fino alla loro rivelazione volontaria da parte dello studente. L'università verificatrice può quindi validare indipendentemente che i campi presentati appartengano effettivamente alla credenziale originale controllando le prove Merkle contro il root hash memorizzato, senza necessità di

contattare l'università emittente o accedere a database centralizzati. Il meccanismo di revoca è implementato come componente nativa dello smart contract, garantendo che ogni verifica di credenziale includa automaticamente un controllo dello stato di revoca. Quando un'università necessita di revocare una credenziale, aggiorna lo stato attraverso una transazione blockchain che registra permanentemente la motivazione e il timestamp della revoca.

3.4.5 Protocollo Sicuro di Trasmissione

Il protocollo sicuro di trasmissione scelto è il **Transport Layer Security (TLS)**.

TLS è un protocollo crittografico standardizzato progettato per fornire sicurezza delle comunicazioni su reti non sicure, in particolare Internet. Il protocollo opera al livello di trasporto del modello OSI, fungendo da layer intermedio tra il protocollo di trasporto (tipicamente TCP) e i protocolli applicativi.

3.4.6 JSON

Il formato scelto per la formattazione delle credenziali è il formato **JSON**.

JSON (JavaScript Object Notation) è un formato di scambio dati leggero, basato su testo e indipendente dal linguaggio di programmazione.

JSON utilizza una sintassi derivata dalla notazione degli oggetti JavaScript, caratterizzata da coppie chiave-valore organizzate in strutture annidate. La sintassi è minimale e intuitiva, rendendo il formato facilmente leggibile sia da esseri umani che da macchine.

4 WP3: Analisi della Sicurezza

Il presente Work Package ha l'obiettivo di analizzare la sicurezza della soluzione progettata in WP2 rispetto al modello di minacce e alle proprietà di sicurezza identificate in WP1. L'analisi si concentra sulla valutazione della resilienza del sistema contro i cinque tipi di attaccanti identificati, verificando il mantenimento delle proprietà di sicurezza richieste. La metodologia di analisi adottata prevede:

- Valutazione della resistenza contro ogni tipologia di attaccante;
- Verifica del soddisfacimento delle proprietà di sicurezza;
- Identificazione di eventuali vulnerabilità e relative contromisure;
- Analisi dell'efficacia dei meccanismi di difesa implementati;

In particolare, si dimostrerà come i meccanismi adottati siano in grado di proteggere il sistema dagli obiettivi definiti di ogni singolo attaccante.

4.1 Studente Disonesto

Lo **Studente Disonesto** è uno studente che vuole ottenere dei vantaggi accademici (miglioramento del proprio voto, aggiunta di esami non realmente sostenuti, etc...) manipolando il sistema. Le risorse che ha a disposizione sono:

- Accesso alle proprie credenziali digitali o ai file certificati;
- Conoscenza di base su formati digitali e strutture di attestazione;
- Eventuale collaborazione con altri attori;

I suoi obiettivi sono:

- **Alterazione delle credenziali ricevute:** modificare localmente un certificato accademico per aggiungere esami, cambiare voti o date;
- **Falsificazione dell'identità dell'issuer:** simulare che una credenziale sia stata rilasciata da un'università legittima;
- **Inganno del verifier:** presentare credenziali manipolate all'università di origine nella speranza che vengano accettate come autentiche;
- **Elusione dei controlli:** sfruttare falle nei meccanismi di verifica;

L'utilizzo di firme digitali RSA-PSS rende impossibile modificare credenziali senza invalidare la firma. Inoltre, il Merkle Root registrato sulla blockchain impedisce modifiche locali non rilevabili, quindi qualsiasi alterazione viene immediatamente rilevata durante la verifica. Lo *Studente Disonesto* non può sostituirsi all'Università Ospitante in quanto i certificati digitali X.509 sono verificabili tramite la Certificate Authority (CA), e solo le università preventivamente accreditate possono firmare credenziali valide.

Non è inoltre possibile ingannare l'Università di Salerno presentando credenziali fasulle, poiché essa può verificare l'autenticità della firma digitale e controllare lo stato di revoca tramite blockchain.

L'elusione dei controlli è una minaccia completamente sventata: la procedura di verifica è automatizzata, la verifica della firma digitale è sempre autonoma e locale, mentre lo stato di revoca richiede interrogazioni blockchain. Quindi, anche compromettendo la connessione, la verifica della firma RSA-PSS continua ad essere efficace; viceversa, se la firma fosse valida ma la credenziale revocata, la blockchain ne rivelerebbe lo stato.

L'unico scenario precedentemente ipotizzabile era quello in cui lo *Studente* collaborasse con un *Funzionario Interno malevolo* per ottenere la generazione di una credenziale su un esame mai sostenuto. Tuttavia, questo attacco è stato reso tecnicamente infattibile: la generazione delle credenziali avviene esclusivamente per esami presenti nel sistema informativo accademico, al quale il sistema accede automaticamente. Il *Funzionario* non può forzare manualmente l'inclusione di esami non registrati nel database.

Di conseguenza, anche scenari in cui attaccanti collaborino tra di loro sono mitigati dal vincolo strutturale alla base della procedura di emissione delle credenziali.

4.1.1 Il Funzionario Interno Malevolo

Il **Funzionario Interno Malevolo** è un operatore all'interno dell'università (sia di origine che ospitante) che abusa delle proprie risorse per alterare, emettere o revocare credenziali in modo fraudolento.

Le risorse che ha a disposizione sono:

- Accesso ai sistemi informatici istituzionali;
- Conoscenza dei protocolli accademici e dei meccanismi di verifica;
- Autorizzazioni per operare su certificati o database interni;

I suoi obiettivi sono:

- Emettere certificati falsi a favore di studenti non meritevoli;
- Revocare certificati autentici per ostacolare la mobilità;
- Modificare i dati contenuti nelle attestazioni per scopi personali o su richiesta esterna;

L'architettura proposta impedisce tecnicamente la realizzazione di tali attacchi.

In particolare, la **generazione delle credenziali** avviene esclusivamente a partire dai dati ufficiali presenti nel sistema informativo accademico dell'Università Ospitante: il funzionario non può inserire manualmente attributi arbitrari. Il contenuto della credenziale viene estratto

automaticamente dagli esami effettivamente registrati nel database accademico dell'ateneo estero.

Dopo la generazione, il Merkle Root della struttura che rappresenta i dati viene registrato sulla blockchain. Qualsiasi tentativo di modifica successiva invaliderebbe il Merkle Proof associato, e la firma digitale RSA-PSS della credenziale non risulterebbe più valida.

Inoltre, l'utilizzo di certificati X.509 emessi da CA accreditate impedisce al funzionario di simulare l'identità di un'altra università, rendendo impossibile l'emissione di attestazioni contraffatte.

Per quanto riguarda la revoca fraudolenta, ogni richiesta di revoca deve essere motivata e firmata, e viene registrata sulla blockchain in modo permanente. La separazione dei privilegi impedisce a un singolo funzionario di eseguire revoche arbitrarie senza supervisione. Eventuali abusi restano comunque tracciabili grazie all'immutabilità del registro distribuito.

Infine, ogni modifica ai dati contenuti nelle credenziali è tecnicamente inibita: l'integrità è garantita dalla firma digitale, e la corrispondenza con il Merkle Root rende impossibili alterazioni non rilevabili.

4.1.2 L'Ingegnere Sociale

L'**Ingegnere Sociale** è un attaccante che sfrutta tecniche di manipolazione psicologica per ingannare studenti, amministrativi o tecnici IT, al fine di ottenere accessi o informazioni riservate.

Le risorse che ha a disposizione sono:

- Email, telefonate, piattaforme social per condurre attacchi di phishing e pretexting;
- Informazioni personali raccolte da fonti pubbliche;
- Esperienza nella creazione di scenari credibili per ottenere la fiducia delle vittime;

I suoi obiettivi sono:

- Ottenere accesso alle credenziali accademiche di uno studente;
- Indurre un dipendente universitario a firmare o approvare certificati fraudolenti;
- Compromettere il sistema di verifica simulando una richiesta legittima.

Il protocollo di autenticazione FIDO2 è intrinsecamente resistente al phishing, poiché vincola l'autenticazione al dominio di origine: eventuali pagine fraudolente non possono attivare la risposta del dispositivo hardware.

L'uso dell'autenticazione biometrica (es. impronta digitale o riconoscimento facciale) rende inefficace il trasferimento dell'identità tramite inganno, poiché la verifica è legata al dispositivo fisico dell'utente.

La procedura di recupero dell'account prevede una fase di identificazione fisica o tramite videocall verificata, riducendo drasticamente la possibilità di recuperi fraudolenti indotti tramite social engineering.

I processi di verifica automatizzati riducono al minimo la discrezionalità del funzionario universitario, che non può approvare certificati non corrispondenti ai dati presenti nel database.

L'accesso alle funzioni di firma è protetto da autenticazione forte (MFA), rendendo più difficile la compromissione anche in caso di manipolazione del dipendente. La presenza di un audit trail immutabile registrato sulla blockchain disincentiva comportamenti dolosi da parte del personale, poiché ogni azione è tracciabile e non alterabile.

La procedura di verifica è completamente automatizzata e fondata su prove crittografiche (firme digitali e Merkle Proof): non è influenzabile da input umani o errori manuali. I controlli crittografici (firma RSA-PSS, controllo revoca, proof Merkle) non sono aggirabili attraverso inganni psicologici, in quanto verificati da codice. La separazione tra la procedura tecnica di verifica e le attività amministrative impedisce che un operatore umano possa interferire manualmente con la validazione di una credenziale.

4.1.3 L'Intercettatore

L'**Intercettatore** è un attaccante che intercetta comunicazioni tra studenti e università, con l'obiettivo di sottrarre dati sensibili o alterare i flussi di trasmissione delle credenziali.

Le risorse che ha a disposizione sono:

- Dispositivi per lo sniffing di rete (es. man-in-the-middle);
- Accesso a reti Wi-Fi insicure in ambienti universitari o pubblici;
- Competenze per analizzare traffico cifrato o non protetto;

I suoi obiettivi sono:

- Rubare certificati accademici o identità digitali durante la trasmissione;
- Sfruttare le informazioni intercettate per impersonare lo studente o l'università;
- Alterare le credenziali in transito;

L'architettura proposta include diverse difese che neutralizzano efficacemente tali attacchi. Tutte le comunicazioni tra studente e università avvengono tramite canali sicuri cifrati con TLS, che garantiscono riservatezza e autenticità.

Le credenziali non sono inviate in chiaro, ma incapsulate in formati firmati digitalmente: anche se intercettate, non possono essere modificate né riutilizzate senza rilevazione.

L'utilizzo di FIDO2 per l'autenticazione protegge l'identità digitale anche in caso di intercettazione della sessione, in quanto non trasmette segreti riutilizzabili.

Le credenziali trasmesse sono protette da firme digitali RSA-PSS e dai corrispondenti Merkle Proofs: qualsiasi alterazione del contenuto invalida automaticamente la verifica.

Anche in caso di attacco man-in-the-middle, l'attaccante non può modificare una credenziale firmata senza renderla invalida per il verificatore.

Meccanismi di timestamp, nonce e session binding prevengono attacchi di replay o cattura/-riuso. Le credenziali possono essere presentate in modo selettivo riducendo l'esposizione di informazioni sensibili.

4.1.4 Il Cacciatore di Vulnerabilità

Il **Cacciatore di Vulnerabilità** è un attaccante che esamina il sistema al fine di cercare vulnerabilità per ottenere l'accesso al sistema. Le risorse che ha a disposizione sono:

- Scanner automatici di vulnerabilità;
- Conoscenze avanzate di sicurezza per identificare e sfruttare vulnerabilità zero-day;
- Capacità di sviluppo;

I suoi obiettivi sono:

- Accedere ai database certificati;
- Compromettere meccanismi di verifica delle firme digitali;
- Vendere le vulnerabilità sul mercato;

Il sistema proposto è stato progettato per limitare drasticamente l'impatto anche di un attacco riuscito, grazie a misure multilivello di protezione.

I database accademici e i registri di credenziali sono protetti da controlli di accesso basati su ruolo e autenticazione MFA, che impediscono l'accesso diretto anche in caso di furto credenziali. Tutti i dati sensibili a riposo sono cifrati e non accessibili in chiaro da applicazioni non autorizzate. Le firme digitali utilizzano RSA-PSS con chiavi lunghe e padding probabilistico, rendendo irrealistico un attacco basato su forza bruta o crittoanalisi. I certificati X.509 sono verificati contro una CA attendibile, e non possono essere sostituiti senza che venga rilevata l'incongruenza. Le credenziali sono validate tramite Merkle Proof, e qualsiasi modifica al contenuto invaliderebbe la root registrata su blockchain.

4.2 Verifica delle Proprietà di Sicurezza

L'analisi condotta nel presente WP3 dimostra che la soluzione progettata è in grado di soddisfare le proprietà fondamentali del sistema.

- **Confidenzialità:** È garantita dall'uso del protocollo TLS per tutte le comunicazioni tra gli attori coinvolti. Inoltre, la strutturazione delle credenziali tramite Merkle Tree consente di applicare meccanismi di *divulgazione selettiva*, riducendo l'esposizione di informazioni sensibili;
- **Integrità:** È assicurata grazie all'utilizzo combinato di firme digitali (RSA-PSS) e della registrazione sulla blockchain del Merkle Root associato alle credenziali. Qualsiasi modifica anche minima ai contenuti invaliderebbe automaticamente la firma o il Merkle Proof;
- **Trasparenza:** L'uso della blockchain Ethereum come registro pubblico e immutabile consente la tracciabilità di tutte le operazioni rilevanti, come l'accreditamento delle università, l'emissione delle credenziali e le eventuali revoche. Ogni attore può quindi verificare autonomamente lo stato delle informazioni, senza dover fare affidamento su sistemi centralizzati;

- **Efficienza:** La progettazione del sistema mira a massimizzare l'efficienza operativa tramite la decentralizzazione dei controlli, l'automazione della verifica crittografica e l'uso di smart contract per orchestrare la gestione delle credenziali. Tuttavia, va notato che la disponibilità può risentire di fattori esterni legati alla rete Ethereum (es. congestione, costi del gas), pur restando entro limiti accettabili grazie alla gestione ibrida con fallback locali;
- **Autenticità:** La validità dell'identità dell'emittente è garantita tramite certificati digitali X.509 emessi da una CA accademica centralizzata. Solo le università preventivamente accreditate possono emettere credenziali accettate dal sistema. In aggiunta, l'autenticazione FIDO2/WebAuthn protegge gli accessi al Wallet dello studente e alle funzioni critiche del sistema;
- **Non Ripudio:** Ogni firma digitale è legalmente vincolante e non può essere rigettata dall'emittente, poiché generata con una chiave privata protetta tramite dispositivi fisici (es. hardware token) e associata a un'identità certificata. Inoltre, tutte le operazioni sono registrate in modo immutabile sulla blockchain, impedendo qualsiasi negazione successiva;

Nel complesso, l'architettura proposta dimostra un elevato livello di conformità rispetto ai requisiti di sicurezza e affidabilità previsti, pur mantenendo un buon equilibrio tra protezione, trasparenza e usabilità.

5 WP4: Implementazione

In questo Work Package, l'obiettivo è quello di implementare una simulazione che dimostri il meccanismo di funzionamento del sistema di credenziali accademiche progettate nel WP2.

5.1 Scelte Implementative e Assunzioni

Innanzitutto, è importante notare che, per motivi di semplicità, sono stati esclusi dalla simulazione alcuni meccanismi proposti nel WP2:

- **Autenticazione degli utenti:** si assume che studenti e funzionari universitari abbiano già effettuato l'accesso ai rispettivi sistemi. In un deployment reale, questo avverrebbe tramite FIDO2/WebAuthn e MFA come specificato nel WP2;
- **Interrogazione database accademico:** nella fase di generazione delle credenziali dello Studente da parte dell'Università di Rennes, era stato proposto un meccanismo attraverso il quale il funzionario dell'Università di Rennes era costretto a interrogare un database al fine di inserire i campi delle credenziali in modo corretto, escludendo quindi lo scenario in cui lo Studente Disonesto, in combutta con il Funzionario Malevolo, emettesse sulla Blockchain dei voti fasulli;
- **Registrazione studenti:** si assume che lo studente si sia già registrato presso entrambe le università;

Inoltre, è necessario fare anche altre assunzioni di motivo tecnico:

- Le chiavi private delle università sono generate e memorizzate senza password per semplicità;
- La blockchain è simulata tramite strutture dati in memoria;
- I canali di comunicazione sicuri (TLS) sono simulati concettualmente;

5.2 Architettura dell'Implementazione

L'implementazione proposta è divisa nei seguenti file:

- **certs.py:** implementazione della Certificate Authority con generazione di Root CA e Intermediate CA e supporto per la creazione di certificati X.509v3 per Università di Salerno e Rennes;
- **merkle_credentials.py:** implementazione del Merkle Tree per abilitare la divulgazione selettiva e genera e verifica Merkle Proof per campi specifici delle credenziali;

- `blockchain_registry.py`: simulazione smart contract Ethereum per la gestione delle credenziali, implementazione della registrazione delle università sulla blockchain e emissione e revoca credenziali. Inoltre, mantiene lo stato delle transazioni immutabile;
- `wallet.py`: gestione della ricezione, della memorizzazione e dell'invio delle credenziali.
- `credential_system.py`: gestione del flusso completo di credenziali e integrazione di tutti i componenti crittografici;
- `main.py`: simulazione del progetto;

5.3 Fasi della Simulazione

Le fasi della simulazione sono:

1. Configurazione Infrastruttura delle PKI Università;
2. Inizializzazione del Wallet Digitale dello studente e richiesta di credenziali all'Università di Rennes;
3. Preparazione delle credenziali da emettere sul wallet digitale dello studente;
4. Firma digitale delle credenziali dall'Università di Rennes;
5. Registrazione delle credenziali sulla Blockchain da parte dell'Università di Rennes;
6. Emissione delle credenziali sul Wallet dello Studente;
7. Generazione della Presentazione selettiva;
8. Verifica delle credenziali da parte dell'Università di Rennes;

5.3.1 Configurazione Infrastruttura delle PKI Università

Attraverso il file `certs.py`, si procede alla creazione della struttura di Autorità Certificatrici. Si divide nelle seguenti fasi:

1. **Creazione Root CA Accademica**: generazione di una coppia di chiavi pubblica e privata e crea un certificato X.509 autofirmato per la Root CA;
2. **Creazione Intermediate CA per Università di Salerno**: generazione di una coppia di chiavi pubblica e privata; successivamente, viene creata una Certificate Signign Request (CSR). La Root CA firma il certificato dell'Università di Salerno;
3. **Creazione Intermediate CA per Université de Rennes**: generazione di una coppia di chiavi pubblica e privata; successivamente, viene creata una Certificate Signign Request (CSR). La Root CA firma il certificato dell'Università di Rennes;
4. **Creazione Catena di Certificati**: viene concatenata il certificato delle Università e certificato della Root, permettendo la verifica della catena di fiducia;

```

=====
FASE 1: CONFIGURAZIONE INFRASTRUTTURA PKI UNIVERSITARIA
=====

Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS

=== CREATECREAZIONE ROOT CA ===
Creating root key (4096 bits)...
Chiave privata salvata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\root\private\root-ca.key.pem
Root del certificato salvato: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\root\certs\root-ca.cert.pem

=== CREAZIONE SALERNO INTERMEDIATE CA ===
Chiave privata salvata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\salerno\private\salerno-ca.key.pem
Certificato dell'Università di Salerno salvato: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\salerno\certs\salerno-ca.cert.pem
Creando salerno certificate chain file...
salerno certificate chain salvato: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\salerno\certs\salerno-ca-chain.cert.pem

=== CREAZIONE RENNES INTERMEDIATE CA ===
Chiave privata salvata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\rennes\private\rennes-ca.key.pem
Certificato dell'Università di Rennes salvato: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\rennes\certs\rennes-ca.cert.pem
Creando rennes certificate chain file...
rennes certificate chain salvato: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\rennes\certs\rennes-ca-chain.cert.pem
Infrastruttura PKI stabilita con successo.

Infrastruttura Digitale Pronta:
  • Root CA Accademica: Autorità fidata per tutte le università
  • Università di Salerno (IT)
  • Université de Rennes (FR)

```

Figura 4: Configurazione Infrastruttura delle PKI Università

5.3.2 Inizializzazione Wallet e Richiesta Credenziali

All'inizio di questa fase viene innanzitutto creato il Wallet Digitale dello Studente, ovvero un sistema che funge da "contenitore sicuro" per le credenziali di un utente. Il Wallet Digitale costruito contiene:

- **Le informazioni dello Studente:** ID dello studente, nome e cognome, email e università di appartenenza;
- **Credenziali ricevute dall'Università di Rennes;**
- **Credenziali inviate all'Università di Salerno;**

Il processo descritto in questa fase si divide in:

1. **Inizializzazione Wallet:** istanziazione del Wallet dello Studente;
2. **Preparazione Richiesta Formale:** lo studente prepara una richiesta formale da inviare all'Università di Rennes;
3. **Richiesta Credenziali:** simulazione tramite canale sicuro TLS della richiesta di credenziali all'Università di Rennes;

```

=====
FASE 2: INIZIALIZZAZIONE WALLET E RICHIESTA DI CREDENZIALI ALL'UNIVERSITÀ DI RENNES
=====

Fase 2.1: Inizializzazione Wallet Digitale di Alessandro
Wallet studente inizializzato: 0622702601
Directory wallet: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\Student_Wallet_ID0622702601
Wallet digitale inizializzato con successo.
  Proprietario: Alessandro Maruotto
  ID Studente: 0622702601
  Università di Origine: salerno

Fase 2.2: Invio Richiesta Ufficiale Credenziali all'Università di Rennes
Dettagli Richiesta:
  ID Richiesta: REQ_RENNES_0622702601_20250721
  Studente: Alessandro Maruotto (0622702601)
  Periodo: 1° semestre 2024
  Corsi: 3 completati

Richiesta inviata con successo all'Ufficio Registrazione di Rennes.

```

Figura 5: Inizializzazione Wallet e Richiesta Credenziali

5.3.3 Preparazione delle Credenziali

In questa fase, l'Université de Rennes riceve e processa la richiesta effettuata dallo Studente. Per abilitare il principio di Divulgazione Selettiva nelle future presentazioni delle credenziali, l'università costruisce un Merkle Tree dove ogni campo dei dati accademici (anno accademico, semestre, singoli esami con relativi voti e crediti ECTS) viene strutturato come una foglia dell'albero. Il Merkle Root risultante verrà successivamente utilizzato per verificare l'integrità dei dati senza rivelare le informazioni non selezionate, garantendo così la privacy dello studente durante le verifiche.

```

=====
FASE 3: RENNES PREPARA LE CREDENZIALI DI INVIARE AL WALLET DELLO STUDENTE
=====

Costruzione Merkle Tree per divulgazione selettiva.

COSTRUZIONE MERKLE TREE
=====
Preparati 6 campi per l'albero
0: academic_year -> 4540858efbe476a1...
1: semester -> 77c5a09b118c1c63...
2: total_ects -> 33afd188ecbedd0c...
3: exam_0 -> c1ab1cc2c70de3e6...
4: exam_1 -> 93242303a5eb4be7...
5: exam_2 -> fae363d4542dcfa6...
Espanso da 6 a 8 foglie
Livello 1: 4 nodi
Livello 2: 2 nodi
Livello 3: 1 nodi
Radice Merkle: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
Merkle Tree costruito con successo.
  • Hash radice: f73a2dc8925b413a84498797200f2d40...
  • Livelli albero: 4
  • Campi dati: 8

```

Figura 6: Preparazione delle Credenziali attraverso un Merkle Tree

5.3.4 Firma Digitale delle Credenziali

L'Università di Rennes, dopo aver costruito il Merkle Tree per la divulgazione selettiva, procede con la preparazione delle credenziali serializzandole in formato JSON e applicando la propria firma digitale.

```
=====
FASE 4: FIRMA DIGITALE DELLE CREDENZIALI DALL'UNIVERSITÀ DI RENNES
=====

Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Credenziali di Firma dell'Università di Rennes caricate
Credenziali:
  ID Credenziale: RENNES_OFFICIAL_0622702601_20250721
  Data emissione: 2025-07-21
  Radice Merkle: f73a2dc8925b413a84498797200f2d40...
  Dimensione dati: 1093 caratteri
Firma RSA-PSS generata
  Lunghezza della firma: 512 bytes
  Lunghezza Base64 : 684 caratteri
Verifica della firma RSA-PSS effettuata con successo
Firma Digitale applicata con successo.
```

Figura 7: Firma Digitale delle Credenziali

5.3.5 Registrazione della Credenziale sulla Blockchain

In questa fase, l'Università di Rennes registra la credenziale inviata allo studente sulla Blockchain. Le transazioni possibili sulla Blockchain sono la registrazione di una università, l'emissione di credenziali accademiche e la revoca di una credenziale. Nello specifico, questa fase si divide in:

1. **Inizializzazione Smart Contract:** viene creata un'istanza simulata dello Smart Contract;
2. **Registrazione delle Università:** l'Università di Rennes viene registrata, generando un transaction_ID e un numero del blocco;
3. **Registrazione della Credenziali:** viene eseguita la transazione sullo Smart Contract, registrando il timestamp, il blocco e aggiornando lo stato della credenziale a "ACTIVE";
4. **Verifica Registrazione sulla Blockchain;**

```

=====
FASE 5: REGISTRAZIONE DELLE CREDENZIALI SULLA BLOCKCHAIN DA PARTE DELL'UNIVERSITÀ DI RENNES
=====

Inizializzazione Smart Contract Credenziali Accademiche
Smart Contract Credenziali Accademiche inizializzato
Funzioni: register_university, issue_credential, revoke_credential, verify_status

REGISTRAZIONE UNIVERSITÀ: rennes
=====
Università registrata con successo
  TX ID: e4081ff8523047d0
  Hash Certificato: 67ebd2f599dd8c2704e7dda6b67273e7e37ba4763ebf69926b0d0473de8ab582
  Blocco: 1
  • Registrazione università: e4081ff8523047d0...

EMISSIONE CREDENZIALE SU BLOCKCHAIN
=====
Credenziale registrata su blockchain
  ID Credenziale: RENNES_OFFICIAL_0622702601_20250721
  Emittente: rennes
  Radice Merkle: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
  TX ID: 94ba8d22bc85539f
  Blocco: 2
Credenziale registrata con successo sulla Blockchain.
  ID Transazione: 94ba8d22bc85539f
  ID Credenziale: RENNES_OFFICIAL_0622702601_20250721
  Radice Merkle: f73a2dc8925b413a84498797200f2d40...
  ID Studente (hash): Protetto per privacy
Verifica blockchain riuscita.
  Stato: active
  Emittente: rennes
  Data emissione: 2025-07-21

```

Figura 8: Registrazione della Credenziale sulla Blockchain

5.3.6 Emissione sul Wallet dello Studente

Una volta registrata la credenziale sulla Blockchain, l'Università di Rennes emette la credenziale in favore dello Studente, che la memorizza sul proprio Wallet Digitale, verificando l'integrità della credenziale.

```

=====
FASE 6: EMISSIONE DELLE CREDENZIALI SUL WALLET DELLO STUDENTE
=====
Utilizzo Wallet esistente: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\Student_Wallet_ID0622702601
Pacchetto credenziali pronto per l'emissione:
  Da: Université de Rennes
  A: Alessandro Maruotto

Emissione della credenziale sull wallet dello Studente

RICEZIONE CREDENZIALE DA RENNES
=====
Credenziale ricevuta da Rennes con successo.
ID: RENNES_OFFICIAL_0622702601_20250721
Studente: Alessandro Maruotto
Esami: 3
File: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\Student_Wallet_ID0622702601\received_from_rennes\RENNES_OFFICIAL_0622702601_20250721.json
Integrità credenziale RENNES_OFFICIAL_0622702601_20250721 verificata
Credenziale ricevuta e verificata con successo.

RIASSUNTO WALLET STUDENTE - 0622702601
=====
Credenziali ricevute da Rennes: 1
Credenziali inviate a Salerno: 0
Directory wallet: C:\Users\maruo\Desktop\Group41_ProjectWork_APS\Student_Wallet_ID0622702601

Statistiche:
  Esami totali da Erasmus: 3

```

Figura 9: Emissione sul Wallet dello Studente

5.3.7 Generazione Presentazione Selettiva

Lo studente, una volta ricevuta la credenziale dall'Università di Salerno, deve presentarla all'Università di Salerno. Lo studente decide di non divulgare tutti gli esami che ha sostenuto, ma solo una parte. In particolare, egli non vuole divulgare all'Università di Salerno di aver sostenuto anche l'Esame di Embedded System, il cui voto è C, e di comunicare all'Università di appartenenza solo il superamento degli esami Software Architecture Design (voto A) e di Machine Learning (voto B+). Lo studente, quindi, genera una Merkle Proof per ogni campo da rivelare e crea la presentazione da mostrare all'Università di Salerno e la invia.

```

=====
FASE 7: GENERAZIONE DELLA PRESENTAZIONE SELETTIVA
=====
Lo studente:
  RIVELA: Software Design Architecture (Voto: A)
  RIVELA: Machine Learning (Voto: B+)
  NASCONDE: Embedded Systems (Voto: C)
Utilizzo campi validi: ['academic_year', 'semester', 'total_ects', 'exam_0', 'exam_1']

GENERAZIONE PROVA PER: academic_year (posizione 0)
Lunghezza percorso prova: 3
  Verificato: academic_year: 2024-2025

GENERAZIONE PROVA PER: semester (posizione 1)
Lunghezza percorso prova: 3
  Verificato: semester: 1° semestre 2024

GENERAZIONE PROVA PER: total_ects (posizione 2)
Lunghezza percorso prova: 3
  Verificato: total_ects: 18

GENERAZIONE PROVA PER: exam_0 (posizione 3)
Lunghezza percorso prova: 3
  Verificato: Software Design Architecture: Voto A (6 ECTS)

GENERAZIONE PROVA PER: exam_1 (posizione 4)
Lunghezza percorso prova: 3
  Verificato: Machine Learning: Voto B+ (6 ECTS)

Informazioni nascoste:
  Nascosto: Embedded Systems: Voto C (6 ECTS)

Presentazione selettiva creata:
  ID Presentazione: PRES_SALERNO_20250721_175445
  Campi rivelati: 5
  Campi nascosti: 1 (voto Embedded Systems)

```

Figura 10: Generazione Presentazione Selettiva

5.3.8 Verifica Università di Salerno

L'Università di Salerno riceve dallo studente la richiesta di convalida degli esami sostenuti all'estero. La fase di verifica si articola nei seguenti punti:

1. **Verifica dello Staro di Revoca:** l'Università di Salerno controlla lo stato della credenziale sulla Blockchain, assicurandosi che essa si trovi nello stato "ACTIVE";
2. **Verifica della Firma Digitale:** se la credenziale risulta essere attiva, l'università di Salerno deve controllare che la credenziale sia effettivamente stata emessa dall'Università di Rennes, verificando la sua firma digitale;
3. **Verifica Merkle Proof:** per ogni prova all'interno della presentazione, viene ricostruito il percorso fino alla Merkle Root, verificando per ogni campo che la prova sia valida;

```
=====
FASE 8: VERIFICA CREDENZIALI DA PARTE DELL'UNIVERSITÀ DI SALERNO
=====
```

```
Fase 8.1: Verifica Stato Blockchain
```

```
Credenziale correttamente caricata.
```

```
Emittente confermato: rennes
```

```
Data emissione: 2025-07-21
```

```
Stato: active
```

```
Fase 8.2: Verifica Firma Digitale RSA-PSS
```

```
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
```

```
Verifica della firma RSA-PSS effettuata con successo
```

```
Firma Digitale verificata con successo
```

```
Fase 8.3: Verifica Prove Merkle Tree
```

```
VERIFICA PROVA PER: academic_year
```

```
Passo 1: sibling right -> de8940b29f506638...
```

```
Passo 2: sibling right -> 8d1535671df605e3...
```

```
Passo 3: sibling right -> f73a2dc8925b413a...
```

```
Hash finale: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Radice attesa: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Prova valida: True
```

```
VERIFICA PROVA PER: semester
```

```
Passo 1: sibling left -> de8940b29f506638...
```

```
Passo 2: sibling right -> 8d1535671df605e3...
```

```
Passo 3: sibling right -> f73a2dc8925b413a...
```

```
Hash finale: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Radice attesa: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Prova valida: True
```

```
VERIFICA PROVA PER: total_ects
```

```
Passo 1: sibling right -> 4688ef59dd39b6a0...
```

```
Passo 2: sibling left -> 8d1535671df605e3...
```

```
Passo 3: sibling right -> f73a2dc8925b413a...
```

```
Hash finale: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Radice attesa: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
```

```
Prova valida: True
```

```

VERIFICA PROVA PER: exam_0
  Passo 1: sibling left -> 4688ef59dd39b6a0...
  Passo 2: sibling left -> 8d1535671df605e3...
  Passo 3: sibling right -> f73a2dc8925b413a...
Hash finale: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
Radice attesa: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
Prova valida: True

VERIFICA PROVA PER: exam_1
  Passo 1: sibling right -> 101cc682819fbd6b...
  Passo 2: sibling right -> fb53458ab79f396d...
  Passo 3: sibling left -> f73a2dc8925b413a...
Hash finale: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
Radice attesa: f73a2dc8925b413a84498797200f2d40bc25890a734ee69efc5bc105a04b0720
Prova valida: True
  Prove Merkle verificata con successo

Fase 8.4: Analisi Crediti Accademici
  Risultati accademici rivelati:
    • Software Design Architecture: Voto A (6 ECTS)
    • Machine Learning: Voto B+ (6 ECTS)

Fase 8.5: Decisione Finale di Salerno
  VERIFICA - CREDITI APPROVATI
  Decisione riconoscimento:
    • Stato: APPROVATO per riconoscimento crediti
    • ECTS riconosciuti: 12

```

Figura 11: Verifica delle Credenziali da parte dell'Università di Salerno

5.4 Test

A supporto della simulazione appena discussa, è presente un ulteriore file, denominato `test.py`, che permette di verificare il corretto funzionamento del sistema. In particolare, esso dimostra come il sistema sia resistente ai seguenti attacchi:

1. **Modifica del Voto:** lo studente riceve la credenziale legittima, ma modifica localmente i dati JSON in modo da cambiare il voto dell'esame di Embedded System da C ad A. Mantiene la firma digitale allegata alla credenziale inviata;
2. **Firma Digitale rubata da un'altra Credenziale Valida:** lo studente ottiene legittimamente una seconda credenziale valida. Prende la firma valida di quella credenziale e la usa per firmare la propria credenziale;
3. **Manomissione della Merkle Root:** lo studente aggiunge un esame mai sostenuto (Advanced Criptography, voto A+). Inoltre, incrementa i crediti ECTS ottenuti, ma mantiene la firma digitale.

Come previsto, tutti questi attacchi vengono respinti dal sistema progettato.

```

ATTACCO 1: MODIFICA VOTO + FIRMA ORIGINALE
=====
Manipolazione eseguita:
  Embedded Systems: C → A
  MANTIENE la firma digitale originale

VERIFICA CON UNIVERSITÀ DI SALERNO - MODIFICA VOTO + FIRMA ORIGINALE
-----
Fase 1: Verifica Firma Digitale
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Certificato caricato correttamente
Verifica della firma RSA-PSS fallita:
  Firma digitale NON VALIDA (atteso)

```

Figura 12: Verifica delle Credenziali da parte dell'Università di Salerno

```

ATTACCO 2: FIRMA RUBATA DA ALTRA CREDENZIALE
=====
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Credenziali di Firma dell'Università di rennes caricate
Firma RSA-PSS generata
  Lunghezza della firma: 512 bytes
  Lunghezza Base64 : 684 caratteri
Manipolazione eseguita:
  Crea altra credenziale: OTHER_CREDENTIAL_123
  Rubata la sua firma per la nostra credenziale
  Firma rubata: PztdsO9WKBmw/nMbH6K0FP1GKBj0Ltf8...

VERIFICA CON UNIVERSITÀ DI SALERNO - FIRMA RUBATA
-----
Fase 1: Verifica Firma Digitale
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Certificato caricato correttamente
Verifica della firma RSA-PSS fallita:
  Firma digitale NON VALIDA (atteso)

```

Figura 13: Verifica delle Credenziali da parte dell'Università di Salerno

```

ATTACCO 3: MERKLE ROOT MANOMESSO
=====
Manipolazione eseguita:
  Root originale: f046dc06f1d1817832cb016cf4fc5b1bef165d895fcb9d1dd062ba2e229530b8
  Root falsificata: 5006c1dd6acc7c275f40ad3bd037b50b92dd7ff37aa4230db3f9c1885eb6e1ce

VERIFICA CON UNIVERSITÀ DI SALERNO - MERKLE ROOT MANOMESSO
-----
Fase 1: Verifica Firma Digitale
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Certificato caricato correttamente
Verifica della firma RSA-PSS fallita:
  Firma digitale NON VALIDA (atteso)

```

Figura 14: Verifica delle Credenziali da parte dell'Università di Salerno

```
ATTACCO 4: AGGIUNTA ESAME FALSO
=====
Manipolazione eseguita:
  Aggiunto esame: Advanced Cryptography (Voto: A+)
  ECTS totali: 18 → 27

VERIFICA CON UNIVERSITÀ DI SALERNO - AGGIUNTA ESAME FALSO
-----
Fase 1: Verifica Firma Digitale
Directory creata: C:\Users\maruo\Desktop\Group41_ProjectWork_APS
Certificato caricato correttamente
Verifica della firma RSA-PSS fallita:
  Firma digitale NON VALIDA (atteso)
```

Figura 15: Verifica delle Credenziali da parte dell'Università di Salerno